

SAFEMPIRE CONSULTING

ISO 27001:2022

ISMS Scoping and Statement of Applicability Workshop

Safempire Health

Telemedicine Platform

Workshop Report and Initial ISMS Documentation

Workshop Date: July 3, 2026

Document Reference: SH-ISMS-WS-2026-001

Version: 1.0

Classification: CONFIDENTIAL

Workshop Summary

This report records the outputs of the ISO 27001:2022 ISMS Scoping and Statement of Applicability Workshop facilitated by Safempire Consulting on behalf of Safempire Health. The workshop brought together key business and technology stakeholders to define the scope of the ISMS, identify and agree on interested parties, and begin the initial drafting of the Statement of Applicability.

Safempire Health is preparing to launch a telemedicine platform that will process sensitive patient health data across multiple jurisdictions. The company has committed to achieving ISO 27001:2022 certification as a condition of partnerships with hospital networks and to demonstrate HIPAA and GDPR compliance to patients and regulators.

Workshop Agenda

Time	Session	Owner	Output
09:00 - 09:30	Introduction, objectives, and workshop overview	Safempire Consulting	Workshop terms agreed
09:30 - 10:30	Stakeholder analysis and interested parties identification	All attendees	Stakeholder register; Interested parties list
10:30 - 11:30	ISMS scoping exercise (business processes, assets, boundaries)	All attendees	Draft ISMS scope statement
11:30 - 12:00	ISMS context and risk landscape overview	CISO / CTO	Risk context agreed
12:00 - 13:00	Lunch break	--	--
13:00 - 15:30	Statement of Applicability initial review (selected controls)	All attendees	Initial SoA draft (25 controls)
15:30 - 16:00	Action items, next steps, and sign-off	All attendees	Action item register

Section 1: Stakeholder Analysis

The following stakeholders participated in the workshop. For each role, the key security and business concerns relevant to the ISMS are documented, along with the questions they raised during the scoping discussion and their specific contributions to the workshop outputs.

Table: Stakeholder Register and Workshop Contributions

Role	Key Interests	Key Concern Raised	Workshop Contribution
Chief Executive Officer (CEO) Chris Alex	Business strategy, investor confidence, and reputational risk management	"How long will certification take, and will it slow down our Q4 launch?" Concern: Platform launch timeline, demonstrating security to hospital partners and investors	Approved budget for ISMS implementation; defined risk appetite; committed to ISO 27001 as a launch prerequisite
Chief Technology Officer (CTO) Dora Chris	Platform architecture, cloud security, DevOps pipeline	"Our platform runs entirely on AWS. Does that mean AWS is in scope for our ISMS?" Concern: AWS shared responsibility model, DevSecOps integration, API security for third-party EHR connections	Confirmed all cloud services in use; provided network architecture diagram; committed to integrating SAST in the CI/CD pipeline
Head of Product Diego Hunt	Product roadmap velocity, user experience, feature development	"Can we run security reviews in parallel with development rather than blocking releases?" Concern: Security reviews slowing down feature releases; developer resistance to security requirements	Provided product roadmap; agreed to add security acceptance criteria to sprint definition of done; allocated developer time for security training
Legal Counsel / DPO Sylvester Gie	Regulatory compliance (HIPAA, GDPR), data subject rights, breach liability	"We process data from both US and EU patients. How does ISO 27001 help us with both HIPAA and GDPR at the same time?" Concern: 72-hour GDPR breach notification requirement; HIPAA Business Associate Agreements with hospital partners; state-level privacy laws	Identified all applicable regulatory frameworks; confirmed GDPR lawful bases for data processing; flagged need for DPIAs before launch; confirmed NDA programme is in place
Head of Clinical Affairs Dens Bee	Clinical workflow continuity, patient safety, provider usability	"Doctors need to access patient records immediately in an emergency. How do we make sure security controls don't block that?" Concern: Security controls disrupting doctor workflows; system downtime during patient consultations; emergency access to patient records	Defined clinical availability requirements (99.9% uptime SLA); confirmed RTO of 4 hours and RPO of 1 hour for production systems; agreed to participate in incident response tabletop
IT / Security Manager Gert Bio	Technical control implementation, endpoint management, monitoring	"We already have some controls in place. How do we formally document what we have without starting from scratch?" Concern: Current gaps in EDR coverage, lack of SIEM, no formal patch management SLA	Provided current IT asset inventory (draft); confirmed existing controls (TLS, partial MFA, daily backups); volunteered to own ISMS implementation roadmap

Interested Parties (ISO 27001 Clause 4.2)

The following parties have an interest in or are affected by Safempire Health's information security programme. Their requirements have been documented and will inform the ISMS design, policy framework, and control selection.

Interested Party	Type	Security Interests	Regulatory / Contractual Requirements
Patients	External	Confidentiality of health data; availability of the platform; right to access and erase records	GDPR data subject rights; HIPAA patient rights (45 CFR 164.524); state-level privacy laws
Healthcare Providers (Doctors, Clinics)	External	Data integrity; platform reliability; professional regulatory compliance	HIPAA Business Associate Agreements; professional licensing obligations; clinical duty of care
Regulatory Authorities (HHS, ICO, DPA)	External	Compliance with HIPAA Security Rule, GDPR, and applicable national health laws	HIPAA Security Rule (45 CFR 164); GDPR (EU 2016/679); national health data protection laws
Investors and Board of Directors	Internal	Risk management; business continuity; reputational and financial protection	Fiduciary duty; investor agreements; SEC disclosure obligations (if applicable)

Interested Party	Type	Security Interests	Regulatory / Contractual Requirements
Technology Partners (AWS, EHR Vendors)	External	Contractual security obligations under shared responsibility; data processing compliance	Service Level Agreements; Data Processing Agreements; Cloud provider acceptable use policies
Pharmacy Networks	External	Prescription data integrity and security; regulatory compliance for e-prescriptions	State pharmacy board regulations; DEA e-prescribing requirements
Employees and Contractors	Internal	Clear security responsibilities; safe working environment; protection from liability	Employment law; NDA obligations; HIPAA workforce training requirements
Cyber Liability Insurers	External	Risk profile assessment; evidence of security controls; incident history	Cyber insurance policy terms and coverage conditions

Section 2: ISMS Scoping Exercise

The scoping exercise was conducted in accordance with ISO 27001:2022 Clause 4.3. The objective was to define the boundary of the ISMS so that it is neither too broad (unmanageable) nor too narrow (creating compliance gaps). The following sub-sections document the workshop outputs.

2.1 Company Profile and External Context

Safempire Health is a healthcare technology startup that has developed a telemedicine platform enabling patients to consult with licensed healthcare providers remotely via video, audio, and secure messaging. The company is preparing for commercial launch with a pilot network of hospital partners and independent practice clinics.

Table: External Context Factors

Context Factor	Description	ISMS Implication
Regulatory Environment	HIPAA Security Rule (US), GDPR (EU patients), FDA Software as a Medical Device (SaMD) guidance, state-level telemedicine regulations	All security controls must align with HIPAA Technical, Physical, and Administrative Safeguards
Competitive Landscape	Competing against established telehealth providers (Teladoc, Amwell). Security certification is a key differentiator for hospital partnerships	ISO 27001 certification is a competitive and contractual requirement for hospital network agreements
Technology Environment	Cloud-native platform on AWS; mobile apps for iOS and Android; third-party EHR integrations via HL7 FHIR APIs	Cloud security, mobile security, and API security controls are all in scope
Threat Environment	Healthcare sector is the most targeted industry for ransomware. PHI sells for up to \$1,000 per record on the dark web	High-priority threat landscape requires proactive detection and response capability
Patient Demographics	Patients across US and EU jurisdictions; includes minors accessing paediatric services	GDPR and COPPA (for minor data) impose additional obligations on data processing

2.2 Key Business Processes

The following business processes were identified as in-scope during the workshop. Each process either handles PHI directly or provides supporting infrastructure to systems that do.

- Patient registration, identity verification, and account management
- Telemedicine consultations (video, audio, and secure messaging channels)
- Electronic health record (EHR) access and integration via HL7 FHIR APIs
- Prescription management and e-prescribing to pharmacy networks
- Patient health data storage, retrieval, and long-term archiving
- Billing and payment processing (including insurance claims management)
- Healthcare provider onboarding, credential verification, and access management
- Software development, testing, and continuous deployment (DevOps pipeline)
- Customer support and clinical helpdesk operations
- Compliance monitoring, audit, and regulatory reporting

2.3 Key Information Assets

The following information assets were identified by the workshop as requiring protection within the ISMS scope.

Asset Category	Examples	Primary Risk	Owner
Patient Health Data (PHI)	Consultation notes, diagnoses, prescriptions, medical images, test results	Unauthorized access; breach notification obligations	Head of Clinical Affairs
Video and Audio Consultation Recordings	Encrypted video streams; session recordings (where consent obtained)	Unauthorized access; breach of patient confidentiality	CTO
Authentication Credentials	Patient and provider login credentials; admin API keys; AWS IAM keys	Account takeover; unauthorized platform access	IT / Security Manager
Source Code and IP	Telemedicine platform source code; algorithms; proprietary clinical workflows	Theft; competitive damage; supply chain compromise	CTO / Head of Product
Payment and Billing Data	Insurance claim data; credit card tokens; billing records	Financial fraud; PCI DSS non-compliance	Head of Finance
Business Information	Contracts with hospital partners; investor data; strategic roadmap	Competitive damage; contractual breach	CEO / Legal Counsel
Third-Party Integration Credentials	EHR API keys; pharmacy network credentials; payment gateway tokens	Unauthorized access to partner systems	CTO
Staff Personal Data	Employee records; payroll; performance data	GDPR obligations; HR privacy requirements	HR Manager

2.4 Locations, Systems, and Departments in Scope

Category	In-Scope Items
Locations	Primary company office (headquarters); all approved remote working environments for staff and contractors
Cloud Infrastructure	AWS production environment (primary region and DR region); staging and development environments in AWS
Core Platform Systems	Patient portal (web and mobile app); Healthcare provider portal; Telemedicine video/audio engine; Prescription management module; Billing and payment system
Development Systems	CI/CD pipeline (GitHub Actions/Jenkins); Code repositories (GitHub); SAST/DAST tooling; Issue tracking (Jira)
Integration Systems	EHR API gateway (HL7 FHIR); Pharmacy network API; Payment gateway integration; SMS/notification services
Supporting Systems	Identity provider (SSO/IAM); SIEM (planned); Backup and DR systems; Monitoring and alerting (AWS CloudWatch)
Departments	Engineering and DevOps; Clinical Operations; Product; Legal and Compliance; Finance; HR; Customer Support

2.5 Formal ISMS Scope Statement

The following scope statement was agreed by all workshop attendees and will be formally recorded in the ISMS Scope Document (Ref: SH-ISMS-SCO-2026-001).

SAFEMPIRE HEALTH -- FORMAL ISMS SCOPE STATEMENT Document Reference: SH-ISMS-SCO-2026-001 Version 1.0 Date: July 3, 2026 The Safempire Health Information Security Management System (ISMS) encompasses all information assets, business processes, technology systems, physical locations, and personnel involved in the design, development, operation, and support of the Safempire Health telemedicine platform (the Platform). The ISMS applies to: - All patient health data (PHI and ePHI) and personally identifiable information processed, stored, or transmitted by the Platform, regardless of format. - All cloud infrastructure (Amazon Web Services) hosting the Platform, including production, staging, and development environments across all in-use AWS regions.
--

- All software development, testing, and deployment processes used to build and maintain the Platform, including the CI/CD pipeline and all associated code repositories.
- Safempire Health's primary office premises and all approved remote working environments used by employees and contractors to access company systems or patient data.
- All Safempire Health employees, contractors, and authorized third parties with access to the Platform, its data, or its underlying infrastructure.
- All third-party integrations and data-sharing arrangements, including EHR system integrations, payment processing partners, pharmacy network APIs, and notification service providers.

Exclusions from ISMS Scope:

- Marketing and advertising activities that do not involve the collection or processing of patient data.
- Third-party healthcare provider systems (hospital EHR systems, clinic management software) that are operated independently by Safempire Health's partner organisations and are not directly integrated with or controlled by the Platform.

Justification for Scope Boundaries:

The scope has been defined to encompass all systems, processes, and people where a security failure could directly impact the confidentiality, integrity, or availability of patient health information. This boundary reflects Safempire Health's obligations under the HIPAA Security Rule (45 CFR Part 164) and GDPR (Regulation EU 2016/679) and aligns with the requirements of ISO 27001:2022 Clause 4.3.

Section 3: Statement of Applicability -- Initial Draft

The following table presents the initial draft Statement of Applicability (SoA) for a selected subset of 24 controls from ISO 27001:2022 Annex A. These controls were selected to represent each of the four control themes and to address the primary risks identified in Safempire Health's pre-workshop risk assessment discussion. The full SoA covering all 93 Annex A controls will be completed as part of the formal ISMS implementation roadmap.

Controls marked (NEW) were introduced in the 2022 revision and did not exist in ISO 27001:2013. The status column reflects the current maturity of each control at the time of this workshop.

Control ID	Control Title	Applicable	Justification	Implementation Approach	Status
ORGANIZATIONAL CONTROLS -- Selected Controls from Theme 1 (5.x)					
5.1	Policies for Information Security	YES	A management-approved Information Security Policy is a foundational ISMS requirement and the primary evidence of leadership commitment required for ISO 27001 certification.	Draft an IS Policy defining security objectives, governance structure, and management commitment. Obtain CEO and Board approval before platform launch. Schedule annual review.	Planned
5.7	Threat Intelligence (NEW)	YES	Healthcare platforms are high-value targets for ransomware and PHI exfiltration. Active threat intelligence enables proactive defence against sector-specific attack campaigns.	Subscribe to HHS HC3 healthcare threat alerts. Subscribe to a commercial threat intelligence feed. Assign the CTO ownership of monthly threat intelligence review and risk register updates.	Planned
5.12	Classification of Information	YES	Patient PHI, consultation recordings, business IP, and administrative data require different protection levels; classification ensures controls are proportionate to data sensitivity.	Define four tiers: Public, Internal, Confidential, and Highly Confidential (PHI). Train all staff. Embed classification requirements in the product backlog for automated data tagging within the platform.	Planned
5.15	Access Control	YES	Unauthorized access to patient data is the primary identified risk. A formal Access Control Policy enforces least-privilege access across all platform components and integrations.	Develop an Access Control Policy. Implement RBAC across the platform and AWS infrastructure. Conduct quarterly access reviews. Define provisioning and de-provisioning SLAs.	Planned
5.17	Authentication Information	YES	Strong authentication for all patient and provider accounts is required to protect PHI and meet HIPAA Technical Safeguard requirements for unique user identification.	Enforce complex password requirements for all accounts. Require MFA (TOTP-based) for all providers and admin users. Implement passkey support for patient mobile app. Rotate service account credentials quarterly.	Partial
5.23	Information Security for Use of Cloud Services (NEW)	YES	The entire Safempire Health platform runs on cloud infrastructure. The AWS Shared Responsibility Model must be formally documented to ensure Safempire Health's obligations are identified and addressed.	Document the AWS Shared Responsibility boundary for each service in use. Conduct quarterly cloud security posture reviews using AWS Security Hub. Assess and formally approve all new cloud services before adoption.	Planned
5.24	Information Security Incident Management Planning	YES	A formal incident management process is mandatory under HIPAA Breach Notification Rule (45 CFR 164.400) and GDPR Article 33, which requires notification to regulators within 72 hours of a confirmed breach.	Develop an Incident Response Plan covering data breach, ransomware, platform outage, and unauthorized PHI access scenarios. Define an incident response team with named roles. Create HIPAA breach notification and GDPR Article 33/34 notification playbooks.	Planned
5.34	Privacy and Protection of PII	YES	Safempire Health processes both PHI (HIPAA) and personal data from EU patients (GDPR). Formal privacy obligations must be documented and operationalised before platform launch.	Appoint a Data Protection Officer (DPO). Publish a Patient Privacy Notice. Implement data subject rights request procedures (access, erasure, portability). Conduct Data Protection Impact Assessments (DPIAs) for all new processing activities involving PHI.	Planned
PEOPLE CONTROLS -- Selected Controls from Theme 2 (6.x)					
6.1	Screening	YES	Healthcare platforms handling patient PHI carry elevated insider threat risk. Background screening of all personnel	Conduct criminal record checks for all employees and contractors. Verify professional credentials for all clinical staff.	Planned

Control ID	Control Title	Applicable	Justification	Implementation Approach	Status
			with access to patient data or clinical systems reduces risk of data misuse.	Embed security screening requirements into contractor and agency agreements.	
6.3	Information Security Awareness, Education and Training	YES	Employees handling PHI must understand phishing risks, data handling obligations, and HIPAA requirements. Human error is the leading cause of healthcare data breaches.	Deploy mandatory annual security awareness training covering phishing, data classification, remote working, and HIPAA obligations. Run quarterly phishing simulations. Provide clinical-specific training on PHI handling. Track completion rates.	Planned
6.6	Confidentiality or Non-disclosure Agreements	YES	All personnel with access to patient data, source code, and business information must sign NDAs to protect PHI and intellectual property before receiving any system access.	Require NDA signature as a condition of employment and contractor onboarding. Maintain a signed NDA register. Post-employment NDA obligations must survive contract termination.	Implemented
6.7	Remote Working	YES	Safempire Health has remote developers and potentially remote clinical coordinators. Formal remote working security requirements protect patient data processed outside the office perimeter.	Define a Remote Working Policy covering VPN requirements, home office security standards, and BYOD restrictions. Enforce full-disk encryption on all laptops. Implement MDM for all devices accessing PHI remotely.	Partial
PHYSICAL CONTROLS -- Selected Controls from Theme 3 (7.x)					
7.1	Physical Security Perimeters	YES	Safempire Health offices contain development workstations and may be used to access patient data; physical perimeter controls prevent unauthorized access to systems holding PHI.	Implement access card control at all office entry points. Enforce visitor sign-in and escort procedures. Restrict server room access to authorized IT staff only. Conduct annual physical security review.	Planned
7.4	Physical Security Monitoring (NEW)	YES	CCTV at office facilities deters physical intrusion and provides evidence for security incidents affecting systems that process or have access to patient data.	Install CCTV at all office entry/exit points and server rooms. Retain footage for a minimum of 30 days. Configure alerts for after-hours access attempts. Document CCTV retention policy in line with applicable privacy laws.	Planned
7.9	Security of Assets Off-Premises	YES	Safempire Health staff use laptops for remote working and may access patient data off-premises. Loss or theft of unencrypted devices is a HIPAA reportable event.	Enforce full-disk encryption (BitLocker/FileVault) on all laptops as a baseline. Implement remote wipe capability via MDM. Require VPN connection before accessing any Safempire Health system. Maintain asset register with off-premises tracking.	Partial
TECHNOLOGICAL CONTROLS -- Selected Controls from Theme 4 (8.x)					
8.1	User Endpoint Devices	YES	All developer and clinical coordinator endpoints must be secured against malware and unauthorized access, particularly as they access patient data, cloud environments, and the development pipeline.	Deploy EDR solution across all endpoints. Enforce OS and application patching within 30 days. Implement application control to restrict unauthorized software installation. Enable full-disk encryption on all devices.	Planned
8.5	Secure Authentication	YES	MFA is a mandatory HIPAA Technical Safeguard and the single most effective control against credential-based attacks, which are the primary entry point in healthcare data breaches.	Enforce MFA using authenticator apps for all staff, patient, and provider accounts. Disable SMS-based OTP for privileged access. Implement single sign-on (SSO) with MFA enforcement. Record MFA adoption rate as a monthly KPI.	Partial
8.7	Protection Against Malware	YES	Ransomware targeting the Safempire Health platform could prevent patient access to care and trigger HIPAA notification obligations. Malware protection is a foundational operational control.	Deploy anti-malware with real-time protection and automatic cloud-based signature updates on all endpoints and servers. Integrate with EDR for behavioural detection. Scan all files uploaded through the patient portal before processing or storing.	Planned
8.12	Data Leakage Prevention (NEW)	YES	Unauthorized exfiltration of patient PHI would trigger HIPAA Breach Notification obligations and GDPR notification requirements, causing significant regulatory and reputational damage.	Implement DLP policies on email and cloud storage to detect and block unauthorized PHI transfers. Configure AWS Macie to scan S3 buckets for PHI. Alert the security team on bulk data exports or unusual data access patterns.	Planned
8.13	Information Backup	YES	Data loss during or after a platform incident is a clinical safety risk and a	Configure automated daily backups of all production databases and patient records to	Partial

Control ID	Control Title	Applicable	Justification	Implementation Approach	Status
			HIPAA violation. Daily automated backups with tested recovery procedures are a minimum requirement for a healthcare platform.	a separate AWS region. Test restoration monthly and document results. Define RTO (4 hours) and RPO (1 hour) for the production platform. Test disaster recovery annually.	
8.24	Use of Cryptography	YES	HIPAA Technical Safeguards require encryption of ePHI. All patient data transmitted through the telemedicine platform and stored at rest must be encrypted using approved cryptographic standards.	Enforce TLS 1.3 for all data in transit between clients and the platform. Encrypt all patient data at rest using AES-256. Implement end-to-end encryption for video consultation streams. Maintain a Cryptographic Key Management Procedure defining key rotation and storage standards.	Partial
8.25	Secure Development Lifecycle	YES	As a software company building a healthcare platform, integrating security into every SDLC phase prevents vulnerabilities in the product from reaching patients and providers in production.	Adopt a Secure SDLC framework. Integrate SAST tools (e.g., SonarQube) in the CI/CD pipeline. Conduct security design reviews for all new clinical features. Require security sign-off before all production deployments. Train all developers in secure coding.	Planned
8.28	Secure Coding (NEW)	YES	Application-layer vulnerabilities in the telemedicine platform could expose patient records to unauthorized access. Secure coding standards directly reduce the platform's exploitable attack surface.	Publish a Secure Coding Standard covering OWASP Top 10 and healthcare-specific risks (injection, authentication, session management). Conduct security-focused code reviews for all PHI-handling modules. Run quarterly developer secure coding workshops.	Planned
8.29	Security Testing in Development and Acceptance	YES	Pre-launch security testing of the telemedicine platform is essential to identify vulnerabilities before patients and providers use it. A breach at launch would be catastrophic for user adoption.	Conduct a full penetration test of the platform and mobile apps before launch. Run DAST scanning (e.g., OWASP ZAP) on every release candidate. Include security acceptance criteria in the definition of done for all user stories involving PHI. Schedule annual third-party pen tests post-launch.	Planned
8.22	Segregation of Networks	YES	Separating development, staging, and production network environments prevents accidental or intentional cross-contamination of patient data between environments.	Implement VPC segregation in AWS separating production, staging, and development environments. Restrict all cross-environment access. Prohibit use of real patient data in development and staging environments. Document network architecture and review quarterly.	Planned

Section 4: Workshop Action Items and Next Steps

The following action items were agreed by all workshop attendees before close of the workshop session. All items are required to progress Safempire Health's ISO 27001:2022 certification. Items marked In Progress were already underway at the time of the workshop.

Table: Action Item Register

No.	Action Item	Owner	Target Date	Status
1	Appoint a CISO or Information Security Manager to own the ISMS implementation	CEO	Within 30 days	Open
2	Draft, review, and obtain CEO approval for the Information Security Policy	CISO / Legal Counsel	Within 45 days	Open
3	Complete the formal IT asset inventory and initial risk register	IT Manager / CTO	Within 30 days	In Progress
4	Conduct the mandatory HIPAA Security Rule risk analysis (45 CFR 164.308)	CISO / Legal Counsel / Safempire Consulting	Within 60 days	Open
5	Develop the Incident Response Plan including HIPAA and GDPR breach notification playbooks	CISO / Legal Counsel	Before platform launch	Open
6	Launch mandatory security awareness training for all staff before platform launch	HR / IT Manager	Before platform launch	Open
7	Procure and configure EDR on all employee endpoints	IT Manager	Within 45 days	Open
8	Enforce MFA for all staff, provider, and admin accounts	IT Manager / CTO	Within 30 days	In Progress
9	Commission pre-launch penetration test of the telemedicine platform and mobile apps	CTO / Safempire Consulting	8 weeks before launch	Open
10	Draft Data Processing Agreements with all third-party data processors	Legal Counsel	Within 30 days	In Progress
11	Conduct Data Protection Impact Assessments (DPIAs) for all PHI processing activities	DPO / Legal Counsel	Before platform launch	Open
12	Select and engage ISO 27001 certification body; confirm certification timeline	CISO / CEO	Within 60 days	Open

4.1 Recommended Next Steps Timeline

Phase	Milestone	Target Timeframe	Dependency
Phase 1 (Now to 45 days)	Appoint CISO; complete IS Policy; enforce MFA; complete asset inventory	Within 45 days	CISO appointment unlocks all other items
Phase 2 (30-90 days)	Complete risk assessment; draft IRP; launch security awareness training; procure EDR	Within 90 days	Asset inventory must be complete
Phase 3 (60-90 days)	Pre-launch penetration test; complete SoA (all 93 controls); DPIAs complete	Before platform launch	Risk assessment and IRP must precede pen test
Phase 4 (Post-launch)	Internal ISMS audit; select certification body; Stage 1 audit (documentation review)	3-6 months post-launch	Full control implementation must be verifiable
Phase 5 (6-12 months)	Stage 2 certification audit; remediate findings; ISO 27001 certification achieved	6-12 months post-launch	Stage 1 audit passed; all critical controls implemented

Section 5: Workshop Sign-Off

The undersigned confirm that they attended the ISO 27001 ISMS Scoping and SoA Workshop on July 3, 2026, and that the workshop outputs documented in this report accurately reflect the agreements reached during the session.

Name	Role	Signature	Date
Chris Alex	Chief Executive Officer	Chris Alex	03/07/2026
Dora Chris	Chief Technology Officer	Dora Chris	03/07/2026
Diego Hunt	Head of Product	Diego Hunt	03/07/2026
Sylvester Gie	Legal Counsel / DPO	Sylvester Gie	03/07/2026
Gert Bio	IT / Security Manager	Gert Bio	03/07/2026
Dike Dee	Workshop Facilitator (Safempire Consulting)	Dike Dee	03/07/2026

This document should be reviewed and updated following each subsequent ISMS workshop or material change to Safempire Health's business operations or technology environment.